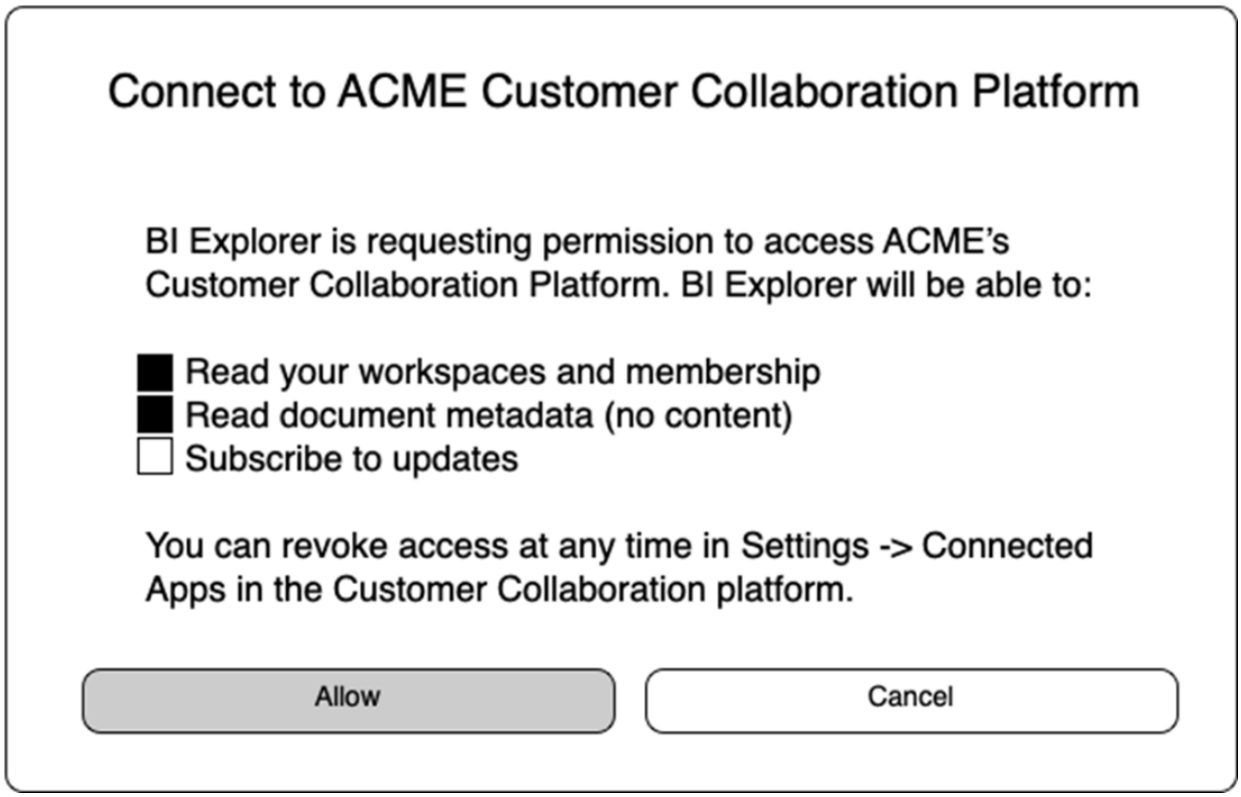


Figure 11.6 OAuth consent screen for BI Explorer. Kate reviews the scopes requested by BI Explorer. She grants permission to read workspace membership, view document metadata (but not content), and does not allow BI Explorer to subscribe to updates. The token issued to BI Explorer will be limited to the scopes Kate selected.

4. **Authorization code issued**. After consent, the authorization server redirects Kate's browser back to BI Explorer with a short-lived authorization code.
5. **Token request**. BI Explorer sends the authorization code to the authorization server directly via an HTTPS request, along with its own client credentials.
6. **Token issuance**. The server verifies the code and returns an access token (and often a refresh token).

At this point, the client, BI Explorer, has a valid access token it can use to call ACME's APIs. Since access tokens are short-lived, the authorization server usually issues a refresh token that BI Explorer can exchange later for a new access token without involving Kate again. This way, Kate isn't repeatedly being prompted to log in or re-consent just to keep her dashboards updated. How the access token is validated and combined with Cedar policies is explained in the later section on using a token.